

PROUDSEC

ShinyHunters: Mass Extortion Campaign & Comprehensive Threat Actor Profile

PROUDSEC | **ShinyHunters** / UNC6040 / UNC6240
Threat Intelligence Report | TLP:WHITE | March 2026



Contents

Introduction	3
Executive Summary	4
Threat Actor Profile	5
Group Structure, Leadership & Alliances	6
Tactical Evolution: 2020 → 2026	7
Current Campaign • Salesforce Experience Cloud (2025–2026)	8
Attack Methodology Deep Dive	9
AI-Powered Vishing Operations	10
Supply Chain & CI/CD Targeting	11
Snowflake Campaign (2024) • Case Study	12
TTPs & MITRE ATT&CK Mapping	13
Known Victims & Historical Breaches	14
Law Enforcement Actions & Arrests	15
Detection & Mitigation Recommendations	15
Dark Web & Underground Forum Evidence	16
Telegram Distribution Evidence	21
Indicators of Compromise (IOCs)	22
References & Intelligence Sources	24



Introduction

This report presents a comprehensive Cyber Threat Intelligence (CTI) analysis of ShinyHunters, one of the most active and financially destructive data extortion groups currently operating at scale. Produced by the PROUDSEC Threat Intelligence Unit, this document is intended to serve as both a strategic briefing for leadership and a technical reference for security operations, incident response, and risk management teams.

The report covers the full threat actor lifecycle • from ShinyHunters' origins in 2019 through their current active campaign targeting Salesforce Experience Cloud environments as of March 2026. It incorporates intelligence from open-source reporting, direct attacker communications, dark web monitoring, technical IOC analysis, and aligned findings from Google GTIG, Mandiant, Eclectiq, Varonis, and Unit42.

Why ShinyHunters Demands Attention Now

ShinyHunters is not a legacy threat. As of the publication date of this report, the group is conducting an active, ongoing exploitation campaign against an estimated 400+ organizations globally. Their targets are not opportunistic • they are deliberate, high-value, and cross-industry. Confirmed victims in the current campaign include Google, Adidas, Qantas, Cisco, LVMH (Louis Vuitton, Dior, Tiffany), Allianz Life, Air France-KLM, and Salesforce itself.

The group's operational model has matured significantly. They no longer rely solely on technical exploitation. In their current phase, they deploy AI-powered voice phishing at industrial scale, weaponize victims' own enterprise infrastructure against them, and coordinate operations across a criminal ecosystem that includes Scattered Spider (UNC3944) and LAPSUS\$. The 2024 Snowflake campaign • which compromised over 160 organizations and exposed hundreds of millions of records • was not an endpoint. It was a proof of concept for what followed.

How to Use This Report

This document is structured to serve multiple audiences simultaneously. Executive and leadership teams will find the most relevant material in the Executive Summary, Threat Actor Profile, and Law Enforcement Actions sections. Security operations and threat intelligence analysts should focus on the TTPs and MITRE ATT&CK Mapping, Indicators of Compromise, and Dark Web Evidence sections. Cloud and Salesforce administrators are directed immediately to Section 5 (Current Campaign) and Section 13 (Detection and Mitigation Recommendations), which contain time-sensitive, actionable guidance. Incident response teams should prioritize the Attack Methodology Deep Dive and the Snowflake Case Study for pattern recognition and forensic context. Security awareness and training leads will find Section 7 (AI-Powered Vishing Operations) directly applicable to updating employee training programs.

Classification & Handling

This report is classified TLP:WHITE and may be freely shared for defensive and awareness purposes within and across organizations. No proprietary or classified government intelligence has been incorporated. All source material is derived from open-source reporting and commercially available threat intelligence, credited in the References section.

Report Type	Classification	Threat Level	Publication Date
Threat Actor Profile + Active Campaign Analysis	TLP:WHITE • Freely Shareable	● CRITICAL • Active Ongoing Campaign	March 12, 2026

Subject	Prepared By	Key Platforms	Version
ShinyHunters / ShinyCorp / UNC6040 / UNC6240	Emircan ALTUNTAŞ, PROUDSEC Threat Intelligence Analyst.	Salesforce, Snowflake, Okta, M365, AWS S3, GitHub	v2.0 • March 2026

Executive Summary

● **CRITICAL ALERT • Active Campaign • Immediate Action Required ShinyHunters (UNC6040/UNC6240) is ACTIVELY exploiting Salesforce Experience Cloud environments as of March 2026. The group claims 400+ companies compromised. Organizations using Salesforce Experience Cloud must audit guest user profile permissions IMMEDIATELY. Salesforce has issued an advisory; Mandiant's CTO confirmed AuralInspector misuse.**

ShinyHunters is one of the world's most prolific and dangerous financially motivated data extortion groups. Operating since 2019–2020, the group has conducted some of the largest data breaches in history, compromising billions of records across hundreds of organizations globally. Their signature model • breach, exfiltrate, extort • requires no file encryption, bypasses traditional ransomware defenses, and leaves limited forensic artifacts.

In 2025–2026, the group escalated dramatically. After the massive Snowflake campaign in 2024 • which alone compromised over 160 organizations including Ticketmaster (560M records), AT&T (110M records), and Santander (30M+ customers) • ShinyHunters pivoted to Salesforce as their next major attack surface.

Key Intelligence Highlights

ShinyHunters is tracked as UNC6040 (vishing/intrusion cluster) and UNC6240 (extortion arm) by Google GTIG. Active campaign against ~400 companies using modified Mandiant AuralInspector tool on Salesforce /s/sfsites/aura endpoints. Custom tool 'RapeForceV2.01.39 (AGENTIC)' identified as the active data extraction tool. Google confirmed its own Salesforce CRM was breached (June 2025). Contact info for SMBs exposed. ShinySp1d3r • VMware ESXi ransomware encryptor • discovered on VirusTotal in late 2025. Four members arrested in France in June 2025; operations continued without interruption. They claim a NEW vulnerability enabling attacks on even properly configured Salesforce instances.

Tactical Evolution Summary

Phase	Timeframe	Primary Method
Phase 1	2019–2022	Exposed database theft, credential leaks, dark web sales
Phase 2	2023–2024	Cloud credential theft (Snowflake), extortion, BreachForums administration
Phase 3	2025–Present	AI-powered vishing, Salesforce exploitation, RaaS development, Scattered Spider + LAPSUS\$ alliance

Threat Actor Profile

Attribute	Detail
Group Name	ShinyHunters
Aliases	ShinyCorp, sp1d3rhunters, shinyc0rp, Scattered LAPSUS\$ Hunters, Trinity of Chaos
Google GTIG Tracking	UNC6040 (intrusion cluster) / UNC6240 (extortion arm)
Active Since	2019 (publicly emerged early 2020)
Origin / Attribution	Unknown • multinational actors; suspected non-state criminal group
Primary Leadership	ShinyCorp (primary persona); identity unconfirmed
Known Members	Rey (Angel RaaS), Yukari/Yuki/yukafeet, Sevy (social engineering); Sébastien Raoult (sentenced 2024)
Current Status	ACTIVE • Ongoing Salesforce mass exploitation campaign (March 2026)
Alliances	Scattered Spider (UNC3944), LAPSUS\$, The Com, Angel RaaS, DragonForce (past)
Infrastructure	Telegram, qTox, BreachStars, OGUsers, DarkForums, LimeWire, BreachForums (past admin)
Target Sectors	Retail, SaaS, Financial Services, Airline, Telecom, Healthcare, Education, Luxury Goods, Insurance
Target Regions	USA, India, Southeast Asia, Europe (UK, France, Germany, Italy), Latin America, South Korea
Primary Attack Surface	Salesforce Experience Cloud, Snowflake, Okta, Microsoft 365/Entra ID, AWS S3, Oracle DB, GitHub
Monetization	Direct extortion • underground data sales • ransomware-as-a-service (shinysp1d3r • in development)
Law Enforcement	4 French members arrested June 2025; Raoult sentenced 2024; Connor Moucka arrested Oct 2024

⚠ ANALYST NOTE • Name Origin: The name 'ShinyHunters' derives from the Pokémon franchise concept of 'Shiny Pokémon' • rare, alternate-color variants that dedicated players actively hunt. This naming reflects the group's strategic pursuit of high-value, rare enterprise data rather than opportunistic low-value consumer credentials.

Group Structure, Leadership & Alliances

Known Personas & Roles

Persona	Role	Known Activities & Attribution
ShinyCorp	Primary Leader	Campaign orchestration; data sales (\$1M/company for airline data); insider recruitment; admin of Sim Land (SL) Telegram channel (Aug 2025)
Yukari / Yuki / yukafeet	Initial Access	Dual member of ShinyHunters & Scattered Spider. SIM swapping, vishing, Oracle Access Manager CVE-2021-35587 exploitation
Rey	Network Access / RaaS	Leads Angel RaaS operations. Brute force attacks against edge devices (VPN/firewall). Exploitation of public-facing servers
Sevy	Social Engineering	Voice call phishing campaigns. Part of Scattered Spider collaboration. Vishing against IT helpdesks at enterprise targets
Sébastien Raoult	Member (SENTENCED)	French national; extradited to US; sentenced Jan 2024 to 3 years (wire fraud + aggravated identity theft); ordered to return \$5M

The Scattered LAPSUS\$ Hunters Alliance (August 2025)

In August 2025, ShinyCorp launched the 'Scattered LAPSUS\$ Hunters' Telegram channel, forming an operational coordination infrastructure with LAPSUS\$ and Scattered Spider members. Intelligence analysts note this represents ecosystem coordination rather than a formal merger, but the combined capabilities are significant:

ShinyHunters contributes • Massive Salesforce exploitation pipeline, stolen database archives, RaaS development (shinysp1d3r), data leak infrastructure.

LAPSUS\$ • Media-driven spectacle extortion, public leak announcements designed to maximize victim shame and pressure.

Scattered Spider (UNC3944) • World-class social engineering, SaaS intrusion expertise, Okta-focused phishing, insider recruitment networks in the USA.

⚠ ANALYST NOTE • Attribution: Multiple threat clusters share the ShinyHunters brand identity. Accurate attribution requires distinguishing entities based on access methods, monetization models, and operational patterns rather than branding alone. This report conservatively attributes confirmed TTPs to the UNC6040/UNC6240 cluster as defined by Google GTIG.

Tactical Evolution: 2020 → 2026

2019–2022: Database Theft Era

In their founding phase, ShinyHunters operated as a large-scale database theft operation. Their primary technique involved identifying exposed cloud databases and misconfigured cloud storage buckets, exploiting them to download credential databases, then monetizing through BreachForums sales and reputation-building public leaks. Early victims (Mathway, Tokopedia, Wattpad, Wishbone) were primarily consumer platforms targeted for their large user databases. Microsoft's GitHub repositories were a notable early escalation • targeting source code rather than consumer PII demonstrated emerging sophistication.

2022–2024: BreachForums Administration & Cloud Credential Pivot

ShinyHunters became administrators of BreachForums, one of the internet's primary underground data trading platforms. This period also saw the group pivot toward cloud platform credential theft, culminating in the 2024 Snowflake campaign. The Snowflake campaign represented a quantum leap in scale and sophistication, targeting at least 160 organizations simultaneously using compromised credentials obtained via infostealer malware. Key innovation: the attackers did not exploit vulnerabilities • they abused valid credentials on accounts lacking MFA.

2024–2026: AI-Augmented Cloud Extortion

The current phase represents ShinyHunters' most sophisticated and ambitious operations to date. Key evolutions include:

- AI voice synthesis: Integration of Bland AI and Vapi for automated, humanlike vishing at scale.
- Platform weaponization: Using victims' own Salesforce infrastructure (Data Loader, Omni-Channel) to conduct attacks.
- Coordinated ecosystem operations: Formal coordination with Scattered Spider and LAPSUS\$ amplifying capabilities.
- RaaS development: Launch of shynosp1d3r ransomware encryptor (VMware ESXi targeting).
- Persistence through arrests: Despite four French member arrests in June 2025 and prior sentencing of Raoult, operations continued without meaningful disruption.

Current Campaign — Salesforce Experience Cloud (2025–2026)

● CRITICAL ALERT • ACTIVE EXPLOITATION • March 2026

Salesforce has issued a security advisory. Mandiant CTO Charles Carmakal confirmed AuralInspector misuse. ShinyHunters claims 400+ companies breached. They have now announced a 'new vulnerability' affecting even properly configured instances. Victims include Google, Adidas, Qantas, LVMH, Allianz Life, Cisco, and AMD.

Campaign Background

Salesforce Experience Cloud is a platform that enables organizations to build customer-facing web portals directly connected to their Salesforce CRM data. When misconfigured, guest profiles can expose CRM objects contacts, accounts, leads • to anyone without authentication. ShinyHunters began scanning for these misconfigurations in September 2025.

Salesforce's own advisory stated: "This issue is not due to any vulnerability inherent to the Salesforce platform, but rather Experience Cloud sites where a guest user profile has been inadvertently configured with overly broad permissions."

The AuralInspector Exploitation Chain

Mass scanning: ShinyHunters modified Mandiant's open-source **AuralInspector** tool for automated mass scanning of `/s/sfsites/aura` API endpoints.

Reconnaissance: The modified tool queries GraphQL APIs to enumerate exposed Salesforce CRM objects.

Exploitation: Using initial guest user access, attackers bypass the 2,000-record query limit via the `sortBy` parameter.

Data extraction: The custom tool '**RapeForceV2.01.39 (AGENTIC)**' is used for bulk CRM record exfiltration.

Pivot via OAuth: Attackers direct employees to `/setup/connect`, establishing unauthorized OAuth connections through modified Salesforce Data Loader applications.

Lateral expansion: Compromised Salesforce environments are leveraged to pivot into Okta, Microsoft 365, and Amazon S3.

Weaponized platform: Salesforce Omni-Channel features are abused to place calls to the victim's own customers.

Extortion: "FINAL WARNING" posts are issued on Telegram and dark web leak sites, with sample data published on LimeWire.

Claimed Scope & Impact

~400 websites / organizations compromised via the Salesforce Aura campaign.

~100 'essential high-profile' companies among the victims.

Some airline datasets: 26GB+ user data, 16GB contact records, 5.5GB email logs, 4.1GB flight data — offered at \$1M per company.

[Figure 1: ShinyHunters Data Leak Site — Active victim listings including Salesforce Aura Campaign (March 2026)]



Escalation: Claimed New Vulnerability

⚠ ANALYST NOTE • Significant Escalation • ShinyHunters has told BleepingComputer they have discovered a new method that enables data theft from even properly configured Salesforce instances • using standard browser user agents (Mozilla/5.0 Windows NT 10.0). This would mean the threat is no longer limited to misconfigured environments. Salesforce is investigating. Until confirmed or denied, organizations should treat all Experience Cloud instances as potentially at risk.

Attack Methodology Deep Dive

Salesforce Data Loader OAuth Abuse

Attackers impersonated Salesforce IT support staff in phone calls, directing employees to navigate to /setup/connect • a legitimate Salesforce setup page. They guided victims to install a modified, malicious version of Salesforce's Data Loader application. Once installed, the malicious Data Loader establishes an OAuth token that grants persistent CRM access without requiring the employee's credentials. This technique is particularly insidious because:

- It uses legitimate Salesforce functionality • no malware deployed on the endpoint.
- The employee's actions appear normal in logs.
- The OAuth token persists even after the employee's password is changed.

The AuralInspector Mass Scanning Phase (September 2025+)

Key technical aspects identified by researchers:

- The tool probes /s/sfsites/aura API endpoints for exposed GraphQL controllers.
- Guest user profiles with 'API Enabled' permissions or 'Export Reports' permissions can be targeted.
- The original 2,000-record limit bypass used the sortBy parameter in GraphQL queries.
- After Salesforce patched the sortBy method, a new bypass was independently discovered and exploited.
- The RapeForceV2.01.39 (AGENTIC) tool handles bulk extraction with the user agent string referencing 'Snowflake attacks'.

Post-Breach Extortion Methodology

Step	Action
1. Silent Period	Maintain access and continue extraction while planning extortion approach.
2. Initial Contact	Private Telegram or email with victim, demonstrating proof via sample data or internal screenshots.
3. Demand Issuance	Cryptocurrency ransom demand issued (Bitcoin or Monero for anonymity).
4. FINAL WARNING Post	If victim does not respond, a public post appears on ShinyHunters' dark web leak portal.
5. Sample Leak	Data samples posted to LimeWire file-sharing service to demonstrate authenticity.
6. Full Leak or Sale	If ransom is unpaid, data is either leaked publicly or sold to other threat actors.

AI-Powered Vishing Operations

A defining characteristic of ShinyHunters' 2025–2026 operations is the systematic deployment of AI-powered voice agents for social engineering at industrial scale. This represents one of the first documented cases of AI voice synthesis being integrated into enterprise cybercriminal campaigns as a core operational capability.

AI Platform Abuse: Bland AI & Vapi

Bland AI: A commercial AI calling platform. ShinyHunters use its built-in LLM to generate conversational pathways tailored to specific enterprise scenarios. The LLM enables dynamic conversation flow • calls remain convincing even when victims respond outside a scripted scenario. Attackers configure voice styles including gender and regional accents to sound human.

Vapi: Another commercial AI voice platform used for real-time voice conversations. Combined with Bland AI, these platforms enable simultaneous vishing campaigns against multiple organizations at a scale impossible with human callers.

Attack Patterns & Behavioral Indicators

- Escalating requests pattern: Calls begin with simple IT requests (password reset) before escalating to MFA modification, RMM installation, OAuth app approval.
- Believable cover stories: All requests framed around mundane IT problems • forgotten passwords, VPN delays, cloud application failures.
- Salesforce setup guidance: Attackers specifically direct victims to '/setup/connect' under the pretext of resolving a Salesforce technical issue.
- Cooperative, non-urgent tone: AI-powered calls use phrases like 'take your time' and 'no rush' • reducing victim suspicion.
- P1 vishing services: Telegram bot-managed automated vishing services placed over Google Voice, Twilio, or 3CX VoIP.

Okta SSO Phishing Infrastructure

- Centralized management: HTTP response headers across all phishing hosts show identical Apache/2.4.58 (Win64) with OpenSSL/3.1.3 fingerprints.
- Anti-law-enforcement taunting: HTTP headers referencing fbi.gov found across infrastructure.
- Evilginx framework: Scattered Spider's Evilginx-based AiTM phishing intercepts session cookies in real time, bypassing MFA.
- Targeting: Investment banking, luxury retail (LVMH Korea breach July 2025), travel industry, US payment processing, major e-commerce.

⚠️ ANALYST NOTE • AI Voice Defense Gap • Traditional security awareness training teaches employees to be suspicious of urgency, threats, or unusual requests. AI-powered vishing calls deliberately avoid ALL these indicators. Organizations must update training to include: verification via internal directories, predefined code phrases for high-risk requests, and video verification for MFA resets.

Supply Chain & CI/CD Targeting

BrowserStack API Key Theft

In the 'Scattered LAPSUS\$ Hunters' Telegram channel (launched August 8, 2025), ShinyCorp leaked BrowserStack access data including: API keys with no expiration dates, keys referencing Cloudflare Access domains and internal Azure-hosted applications, and enterprise domain-tied keys enabling pivot into broader engineering workflows.

BrowserStack integrates with CI/CD platforms (GitHub, GitLab, Jenkins, Azure DevOps), collaboration tools (Jira, Slack), and test automation frameworks. A single leaked API key can expose an organization's test environments, source code, build processes, and deployment pipelines.

Oracle Access Manager Exploitation

Element	Detail
CVE	CVE-2021-35587 • Oracle Access Manager 12c (12.2.0.1.0)
Persona	Yukari
Target	Financial institutions and manufacturing companies
Method	Abuse of weak, hard-coded credential stored on the application server
Execution	SQL*Plus used to run direct database queries and exfiltrate records
Impact	Direct access to production Oracle databases with DBA-level privileges



GitHub Source Code Theft

In early 2020, ShinyHunters stole over 500GB of source code from Microsoft's private GitHub repositories • one of the most high-profile intellectual property theft incidents of the decade. This established a pattern of targeting source code and development infrastructure that continues in their CI/CD-focused supply chain attacks today.

 **ANALYST NOTE • Supply Chain Priority • Any organization using BrowserStack, JFrog Artifactory, GitHub, or Cloudflare Access should immediately audit API key exposure. Require expiration dates on ALL service credentials. Audit OAuth app approvals in Salesforce and other SaaS platforms for unauthorized connected applications.**

Snowflake Campaign (2024) — Case Study

Campaign Overview

In mid-2024, at least 160 organizations were compromised via their Snowflake cloud data warehouse environments. Snowflake confirmed that the breaches were caused by compromised customer credentials obtained via infostealer malware • not any Snowflake platform vulnerability. Affected accounts notably lacked multi-factor authentication. Once authenticated, attackers used a custom tool named 'RapeFlake' to systematically exfiltrate customer databases.

Confirmed Victims

Organization	Data Stolen	Year
Ticketmaster / Live Nation	560 million customer records; 1.3TB; PII, payment data, order history. \$500K demand.	2024
Santander Bank	All staff + ~30 million customers in Spain, Chile, Uruguay. Banking credentials and PII.	2024
AT&T Wireless	110 million customer records; call/text logs for nearly all customers. \$370K ransom paid.	2024
Advance Auto Parts	79 million unique emails + PII. Sold for \$1.5M on BreachForums.	2024
Neiman Marcus	31 million customer emails and partial payment info exposed.	2024
LendingTree / QuoteWizard	2TB of data claimed for sale at \$2M.	2024
LA Unified School District	Staff and student data; district faced service disruption.	2024
Pure Storage	Employee and customer data; attacker accessed a Snowflake workspace.	2024
PowerSchool	62.4M student + 9.5M teacher records. \$2.85M ransom paid. Follow-on district extortion 2025.	2024–25

Law Enforcement Response

Connor Riley Moucka (aliases: Waifu, Judische, Ellyel8) • arrested Kitchener, Ontario, Canada, October 30, 2024.
John Erin Binns (aliases: IRDev, IntelSecrets) • arrested Turkey, May 2024. Detained pending extradition.
Despite these arrests, ShinyHunters operations continued without significant disruption.

 **ANALYST NOTE • Snowflake → Salesforce Pattern • The structural similarities between the 2024 Snowflake campaign and the 2025–2026 Salesforce campaign suggest a deliberate strategy of targeting major cloud platforms via their customer-configuration attack surfaces rather than platform vulnerabilities. Organizations should proactively audit guest/public access configurations across ALL SaaS platforms.**

TTPs & MITRE ATT&CK Mapping

Tactic	Technique	Description
Initial Access	T1190	Exploit Public-Facing Application • Modified AuralInspector mass scanning of Salesforce /aura endpoints
Initial Access	T1078	Valid Accounts • Stolen Snowflake credentials via infostealer malware; Okta SSO credential harvesting
Initial Access	T1566.002	Spearphishing Link • Cloned Okta login pages targeting investment banks, luxury retail, travel sector
Initial Access	T1133	External Remote Services • VPN/firewall edge device brute force by Rey (Angel RaaS)
Initial Access	T1195	Supply Chain Compromise • BrowserStack API key theft enabling CI/CD pipeline access
Execution	T1059.004	Unix Shell • SQL*Plus queries against Oracle Access Manager (CVE-2021-35587)
Execution	T1204.001	User Execution: Malicious Link • Salesforce /setup/connect OAuth token theft via help desk vishing
Execution	T1059.003	Windows Command Shell • RapeForceV2.01.39 (AGENTIC) bulk extraction scripts
Persistence	T1078.004	Valid Accounts: Cloud Accounts • OAuth tokens persist beyond password changes
Priv. Escalation	T1068	Exploitation for Privilege Escalation • CVE-2021-35587 Oracle Access Manager
Defense Evasion	T1090	Proxy • Commercial VPN and Njalla-registered domains to conceal attacker infrastructure
Defense Evasion	T1036	Masquerading • Modified Data Loader appearing as legitimate Salesforce admin tool
Credential Access	T1539	Steal Web Session Cookie • Evilginx AiTM phishing intercepting Okta session cookies in real time
Credential Access	T1528	Steal Application Access Token • BrowserStack API keys, OAuth tokens, Cloudflare Access tokens
Credential Access	T1111	MFA Interception • Help desk social engineering; MFA fatigue attacks
Credential Access	T1556	Modify Authentication Process • Enrolling attacker-controlled MFA devices via help desk
Discovery	T1526	Cloud Service Discovery • Mapping Okta integration points (AWS S3, Azure, Slack, HR systems)
Discovery	T1518	Software Discovery • Enumerating Salesforce CRM object schema pre-exfiltration
Lateral Movement	T1210	Exploitation of Remote Services • Salesforce OAuth → Okta → M365 → AWS S3 pivot chain
Collection	T1213	Data from Information Repositories • Bulk Salesforce CRM export; 26GB+ per airline victim
Collection	T1119	Automated Collection • AuralInspector mass scanning; RapeForceV2.01.39 bulk extraction
C2	T1102	Web Service C2 • Telegram and qTox for command, coordination, and extortion communications
Exfiltration	T1567.002	Exfil to Cloud Storage • Data transferred to attacker-controlled cloud environments
Exfiltration	T1041	Exfil over C2 Channel • LimeWire used for public sample leak posts to increase extortion pressure
Impact	T1486	Data Encrypted for Impact • shinysp1d3r ransomware (VMware ESXi targeting; in development)



Resource Dev.	T1583.006	Acquire Web Services • VoIP services (Bland AI, Vapi, Google Voice, Twilio) for vishing
Resource Dev.	T1588.002	Obtain Capabilities: Tool • Modified AuralInspector, RapeForceV2.01.39 malicious Data Loader

Known Victims & Historical Breaches

Part 1: 2020–2023

Organization	Incident Detail	Year
Mathway	~25 million user records from the math tutoring app	2020
Tokopedia	91 million user accounts • emails, usernames, hashed passwords, location	2020
Wattpad	270 million user records • names, emails, passwords, location data	2020
Microsoft GitHub	500GB+ source code stolen from private repositories	2020
Wishbone	Full user database including PII and hashed passwords	2020
Pluto TV	3.2 million user records including IPs and display names	2020
Animal Jam	46 million accounts exposed	2020
Mashable	5.22 GB database leaked on hacker forum	2020
Pixlr	1.9 million user records leaked publicly	2021
Nitro PDF	77 million user records leaked for free • credential damage across enterprises	2021
Bonobos	7M customer records, 1.8M registered accounts, 3.5M partial credit card records	2021
AT&T Wireless (first)	70M subscriber records sold (SSNs, personal info) • AT&T acknowledged breach in 2024	2021
Aditya Birla Fashion	5.4M unique emails + extensive PII after ransom refused — data dumped publicly	2021
Pizza Hut Australia	1M+ customer records, 30M order records	2023

Part 2: 2024 Snowflake Campaign

Organization	Data Stolen	Year
Ticketmaster / Live Nation	560M customers; 1.3TB data; PII + payment data. \$500K demand.	2024
Santander Bank	All staff + ~30M customers in Spain, Chile, Uruguay.	2024
AT&T Wireless (second)	110M customer records; call/text metadata. \$370K ransom paid.	2024
Advance Auto Parts	79M unique emails + PII. Sold for \$1.5M on BreachForums.	2024
Neiman Marcus	31M customers; PII + partial payment card info.	2024
PowerSchool	62.4M student + 9.5M teacher records. \$2.85M ransom paid.	2024–25

Part 3: 2025–2026 Salesforce Campaign

Organization	Incident Detail	Year
Google	Salesforce CRM breached via UNC6040 OAuth vishing (June 2025). Contact data for SMBs exposed.	2025
Qantas Airways	~6M customer records; contact details + flight booking data exfiltrated.	2025
LVMH (Louis Vuitton, Dior, Tiffany)	Luxury retail CRM data. Extortion emails sent to leadership.	2025
Allianz Life Insurance	2.8M policyholder records including financial data.	2025



Cisco	Salesforce CRM data exfiltrated. Internal business records and partner contact data.	2025
Air France-KLM	Frequent-flyer and contact data.	2025
Adidas	Customer CRM records via Salesforce Aura campaign.	2025
Salesforce + ~400 orgs	ACTIVE • CRM records via AuraInspector exploitation. Ongoing as of March 2026.	2025–26

Law Enforcement Actions & Arrests

● CRITICAL ASSESSMENT • March 2026 Salesforce Campaign

The March 2026 Salesforce campaign began **AFTER** all known arrests were made. Organizations should **NOT** reduce vigilance or defensive investments based on law enforcement actions. All 5 enforcement actions produced **ZERO** operational disruption.

Date	Subject	Action & Outcome
Jan 2024	Sébastien Raoult	French national extradited to US. Sentenced 3 years (wire fraud + aggravated identity theft). Ordered to return \$5M.
May 2024	John Erin Binns	Aliases: IRDev, IntelSecrets. Arrested Turkey; linked to 2021 T-Mobile breach + Snowflake campaign. Detained pending extradition.
Oct 2024	Connor Riley Moucka	Aliases: Waifu, Judische, Ellyel8. Arrested Kitchener, Ontario. Faces charges in Washington State for Snowflake campaign.
May–Jun 2025	Matthew D. Lane	19-year-old MA student. Charged by DOJ with hacking and extorting PowerSchool. Demanded \$2.85M BTC ransom.
Jun 2025	4 French Nationals	Identities not publicly disclosed. French law enforcement operation. Operations continued without interruption.

Operational Continuity Assessment: ShinyHunters uses online-only pseudonymous identities with no geographic consolidation. Distributed leadership prevents decapitation. Affiliate model enables continuation after core member removal.

Detection & Mitigation Recommendations

Salesforce Experience Cloud — Immediate Priority

⚠ **Salesforce has issued an official security advisory • Complete the below steps within 24–48 hours. Mandiant's CTO confirmed that detecting scanning activity in logs does NOT by itself indicate compromise • but mandates immediate permission audit.**

Audit Guest User Profiles: Navigate to **Setup > Profiles > Guest User Profile** for each Experience Cloud site and verify object-level security settings.

Revoke Dangerous Permissions: Remove **'API Enabled'**, **'Export Reports'**, and **'View All Data'** permissions from all guest user profiles.

Monitor /aura Endpoints: Enable **Salesforce Shield Event Monitoring**. Set alerts for bulk unauthenticated GraphQL queries and flag the **'RapeForce'** string in user agent logs.

Audit OAuth Connected Apps: Revoke all unrecognized OAuth tokens, focusing specifically on those granted via **Data Loader** variants.

Implement SSPM: Deploy a **SaaS Security Posture Management (SSPM)** solution for continuous monitoring of misconfigurations.



SIEM Alerts: Configure alerts for new MFA device enrollments, bulk CRM exports, new OAuth app approvals, and unauthenticated API calls exceeding **200 records/minute**.

Identity & MFA Hardening

Enforce FIDO2 hardware keys or passkeys for all users with access to Salesforce, Okta, M365, Snowflake, and AWS. Disable SMS and voice call MFA options for all privileged accounts. Enable Okta ThreatInsight + Microsoft Entra ID Protection. Block authentication from commercial VPN exit nodes, Tor, and unfamiliar geographic regions. Immediately audit and rotate all BrowserStack, GitHub, JFrog Artifactory, and Cloudflare Access API keys.

AI Vishing Defense

KEY INDICATOR: Any unsolicited call directing staff to /setup/connect in Salesforce = **CONFIRMED** social engineering attempt. **Internal Callback Policy:** Verify ALL inbound caller identity via internal callback • **NEVER** callback number provided by caller. **Challenge-Response Code Words:** Predefined shared phrases for high-risk requests. Rotate monthly. **Video Verification:** Require Teams/Zoom face verification for MFA device resets and OAuth app approvals. **Update Security Awareness Training:** AI calls are calm and professional, not urgent or threatening.

Dark Web & Underground Forum Evidence

ShinyHunters Data Leak Site (DLS) — Active Infrastructure

ShinyHunters operates a dedicated Data Leak Site (DLS) accessible via Tor hidden services. The site • branded 'SHINYHUNTERS / Rooting your systems since '19' • lists active victims with download links, record counts, SHA-256 checksums, and extortion messages. The 'NOTICE OF WARNING' mechanism gives companies a final window to pay before full public release.

The Salesforce Aura Campaign listing (Updated: 10 Mar 2026) shows 2,872 entries. Additional victims include: CFGI Management (800K+ records, 40K+ financial docs), Woflow/DoorDash/Deliveroo (326GB), Odido NL/Ben.nl (15M+ records, 88GB+), Mercer Advisors (5M+), CarGurus (12.4M+).

DLS Extortion Messages

SALESFORCE AURA CAMPAIGN WARNING (Mar 2026): "Several hundreds of companies set to release with FINAL WARNINGS upon failure to comply. To all affected companies • please consider this a preliminary warning before we release your name. Reply, engage, pay a small price, and prevent a publication. Make the right decision, don't be the next headline."

ODIDO NL EXTORTION MESSAGE (Mar 2026): "Over 15M Salesforce records containing Full Names, Physical addresses, email addresses, phone numbers, plaintext passwords, IBAN, passport numbers, driver license numbers. This is your fault, Odido. You are the reason why an entire country is about to suffer. Indefinitely."

WOFLOW EXTORTION (Post-Leak): "If you were freaking out... now you should really be freaking out. Next time pay the ransom ;). Make the right decision, don't be the next headline. It was in your best interest to pay, but you didn't."

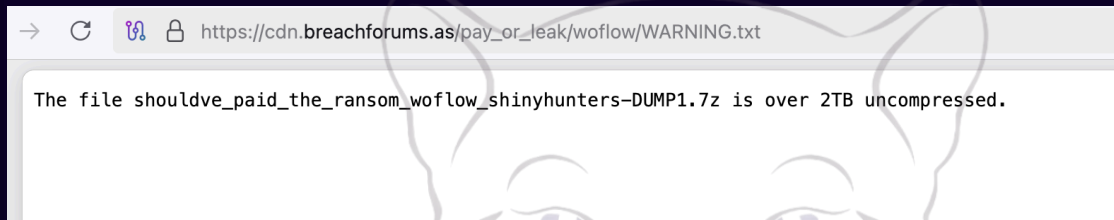
[Figure 2: BreachForums CDN — Index of /pay_or_leak/woflow/ showing 326GB data dump]

Index of /pay_or_leak/woflow

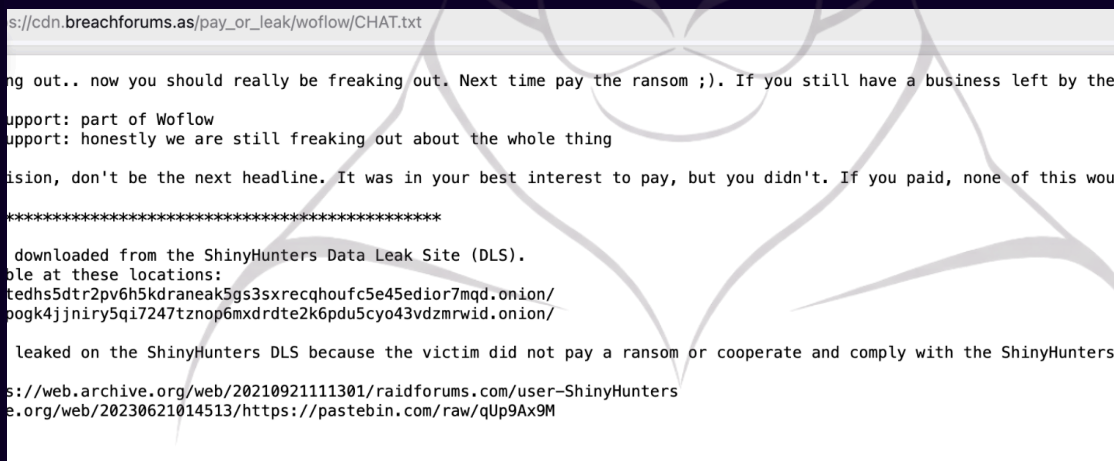
Name	Last modified	Size	Description
 Parent Directory		-	
 CHAT.txt	2026-03-07 14:48	1.0K	
 WARNING.txt	2026-03-07 14:57	89	
 shouldve_paid_the_ransom_woflow_shinyhunters-DUMP1.7z	2026-03-07 14:23	326G	

Apache/2.4.66 (Debian) Server at cdn.breachforums.as Port 443

[Figure 3: BreachForums CDN — WARNING.txt confirming 2TB+ uncompressed data]



[Figure 4: CHAT.txt — Woflow internal communication leaked alongside data dump]

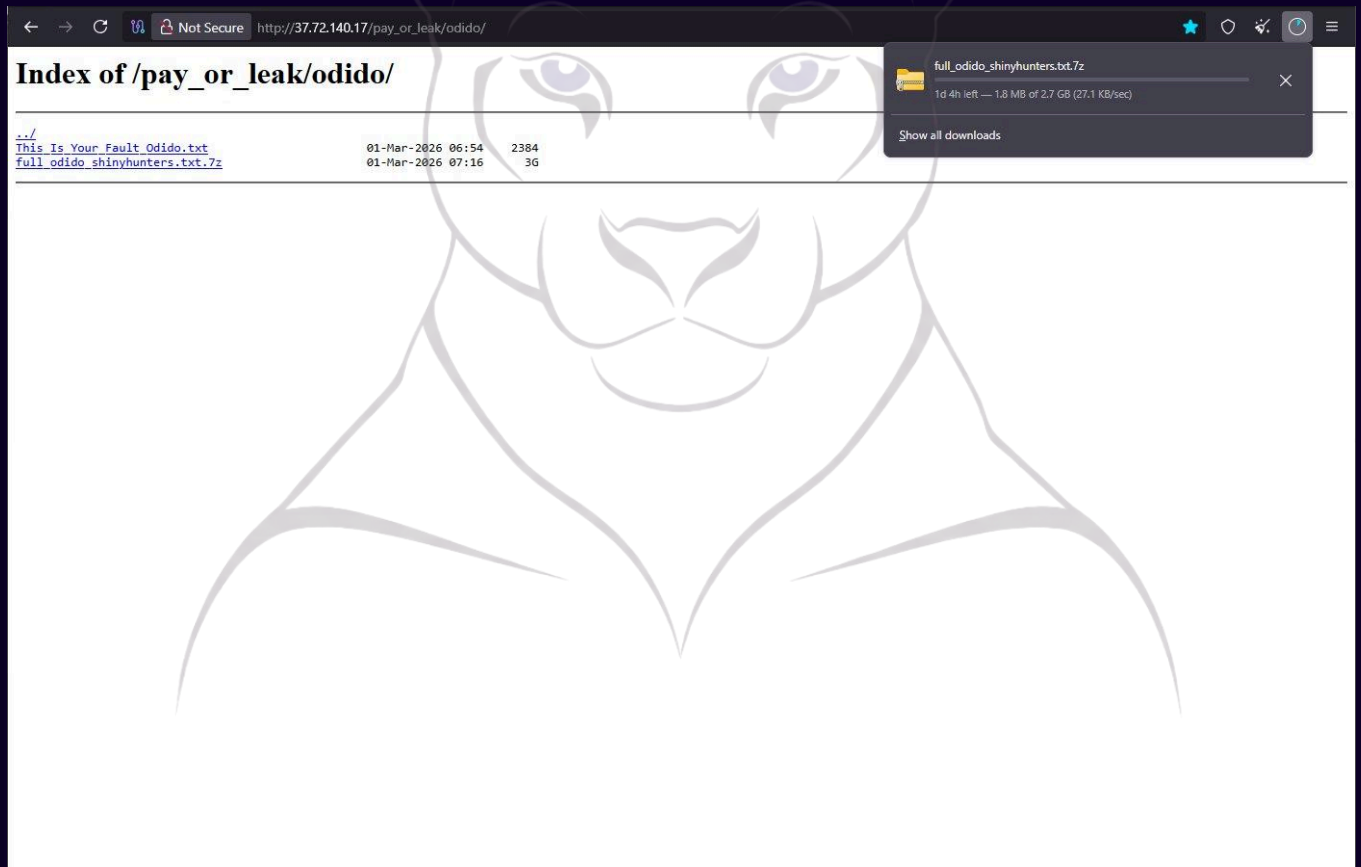


Odido NL — Full Leak Documentation

[Figure 5: BreachForums CDN — Index of /pay_or_leak/odido/ showing 2.7GB compressed full dataset]

Index of /pay_or_leak/odido				
Name	Last modified	Size	Description	
 Parent Directory		-		
 This_Is_Your_Fault_Odido.txt	2026-03-04 22:38	2.3K		
 full_odido_shinyhunters.txt.7z	2026-03-05 02:49	2.7G		

[Figure 6: Odido mirror server (37.72.140.17) with active 2.7GB download in progress]



Index of /pay_or_leak/odido/

..		
This_Is_Your_Fault_Odido.txt	01-Mar-2026 06:54	2384
full_odido_shinyhunters.txt.7z	01-Mar-2026 07:16	3G



[Figure 7: This_Is_Your_Fault_Odido.txt — Full extortion message posted by ShinyHunters]

```
achforums.as/pay_or_leak/odido/This_Is_Your_Fault_Odido.txt

cision, in every and any way possible. We approached you privately with terms. We were reasonable. You declined. That option no longer exists.

to resolve this quietly and within days. Instead, you chose delay and disclosure. The consequences will now be public, prolonged, and expensive.

d very clear to every company around the world. Let this set the record straight. If we ("ShinyHunters") ever contact you to reach an agreement, it w
and PAY the ransom. Failure to engage will result in immediate escalation and controlled public exposure. Maximum public and reputational embarrassme
s, stakeholders, and investors. Your business. Simply put, pay us and your data is deleted, we go away. Anything else besides this will bring you man

finition, and example of "Fuck Around, Find out." We are not messing around. We are not bluffing nor are we exaggerating.

e for this. Blame Odido. It is their fault. They store highly sensitive data in third party platforms ("Salesforce"), for more than 10 years. That in
care about their customers, they don't care about you. Odido, you are the reason for the infliction of fear and terror among the citisens of Nederlan
o reach an agreement with us. *This is NOT our fault*.

n't be the next headline and pay the ransom. Or become the headlines and what an example we will make out of you.

*****

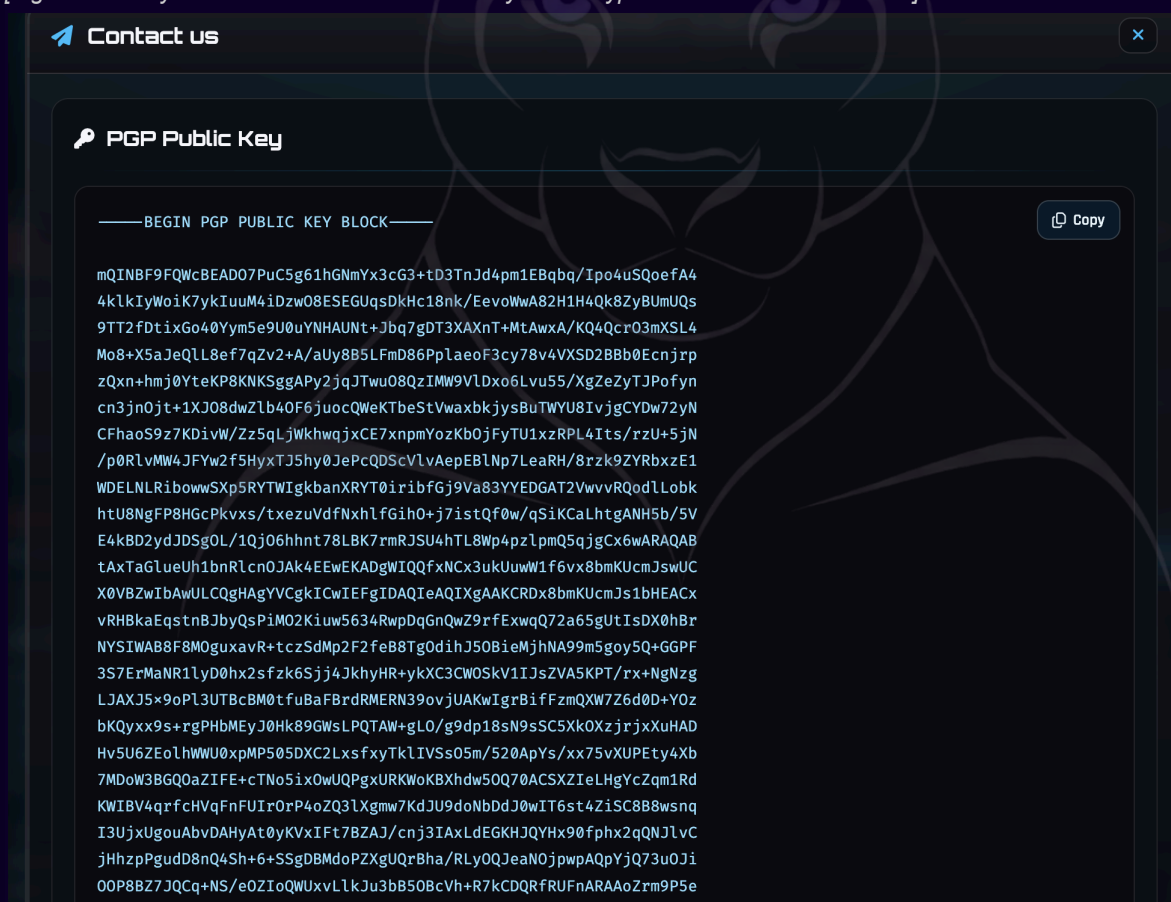
ed from the ShinyHunters Data Leak Site (DLS).
ese locations:
2pv6h5kdraneak5gs3srecqhoufc5e45edior7mqd.onion/
ry5qi7247tznop6mxdrdte2k6pdu5cyo43vdmrwid.onion/

n the ShinyHunters DLS because the victim did not pay a ransom or cooperate and comply with the ShinyHunters group.

rchive.org/web/20210921111301/raidforums.com/user-ShinyHunters
/20230621014513/https://pastebin.com/raw/qUp9Ax9M
```

DLS Contact Infrastructure

[Figure 8: ShinyHunters DLS — PGP Public Key for encrypted victim communications]



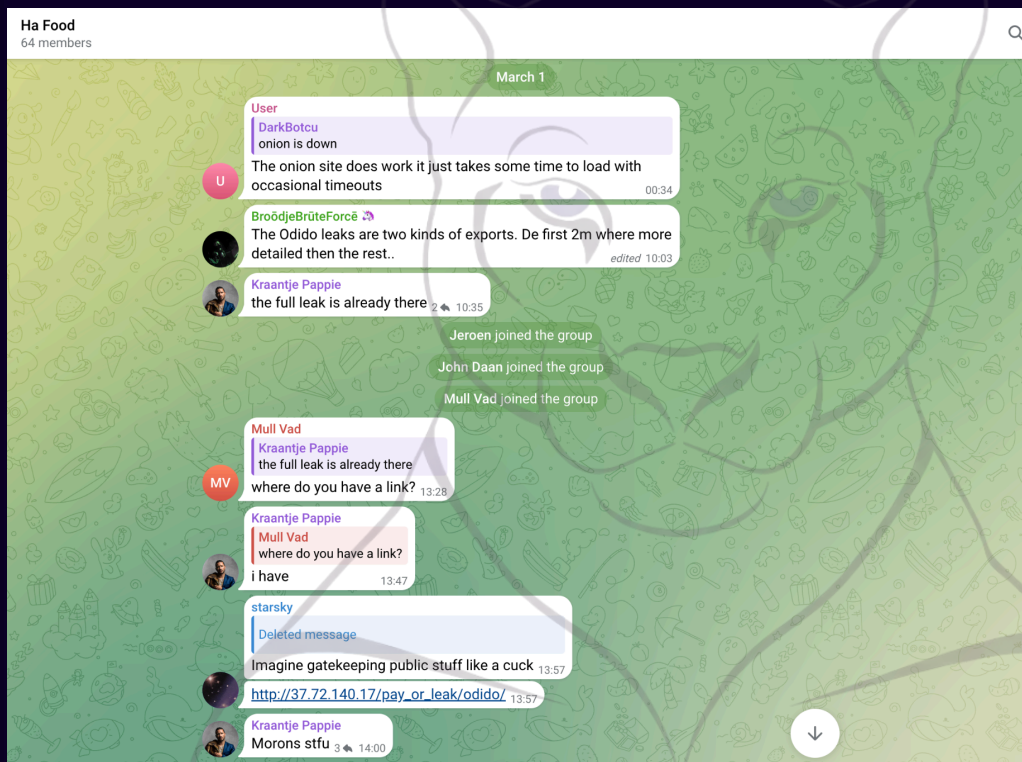
Telegram Distribution Evidence

Following public leak publication on ShinyHunters' DLS and BreachForums, stolen data is rapidly redistributed through secondary Telegram channels. These groups — not operated by ShinyHunters directly — serve as distribution hubs where third parties download, share, and trade the leaked data, compounding victim impact.

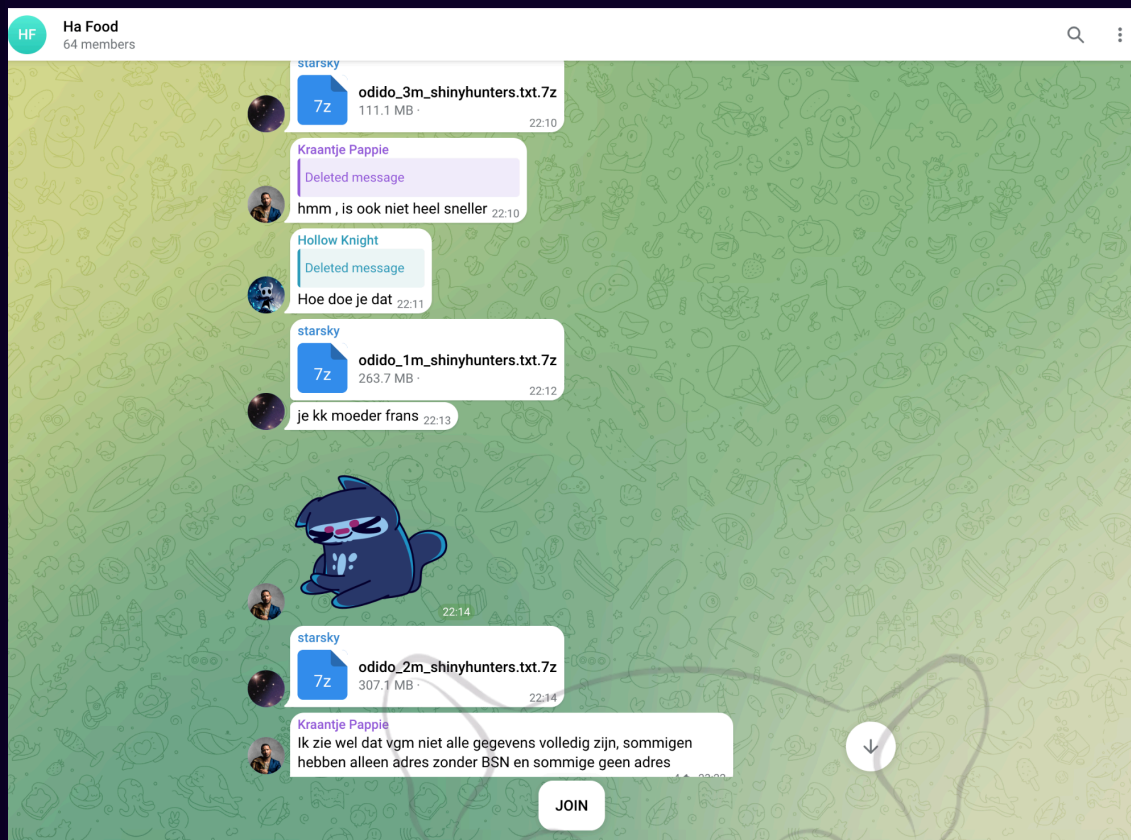
The 'Ha Food' Telegram group (64 members, observed March 2026) illustrates the ecosystem: within hours of the Odido NL leak publication, users were sharing direct download links, discussing data completeness, reporting server overload from mass simultaneous downloads, and verifying whether leaked records contained passwords and BSN (Dutch national ID) numbers.

Observed Telegram Activity • Ha Food Channel (March 1, 2026)

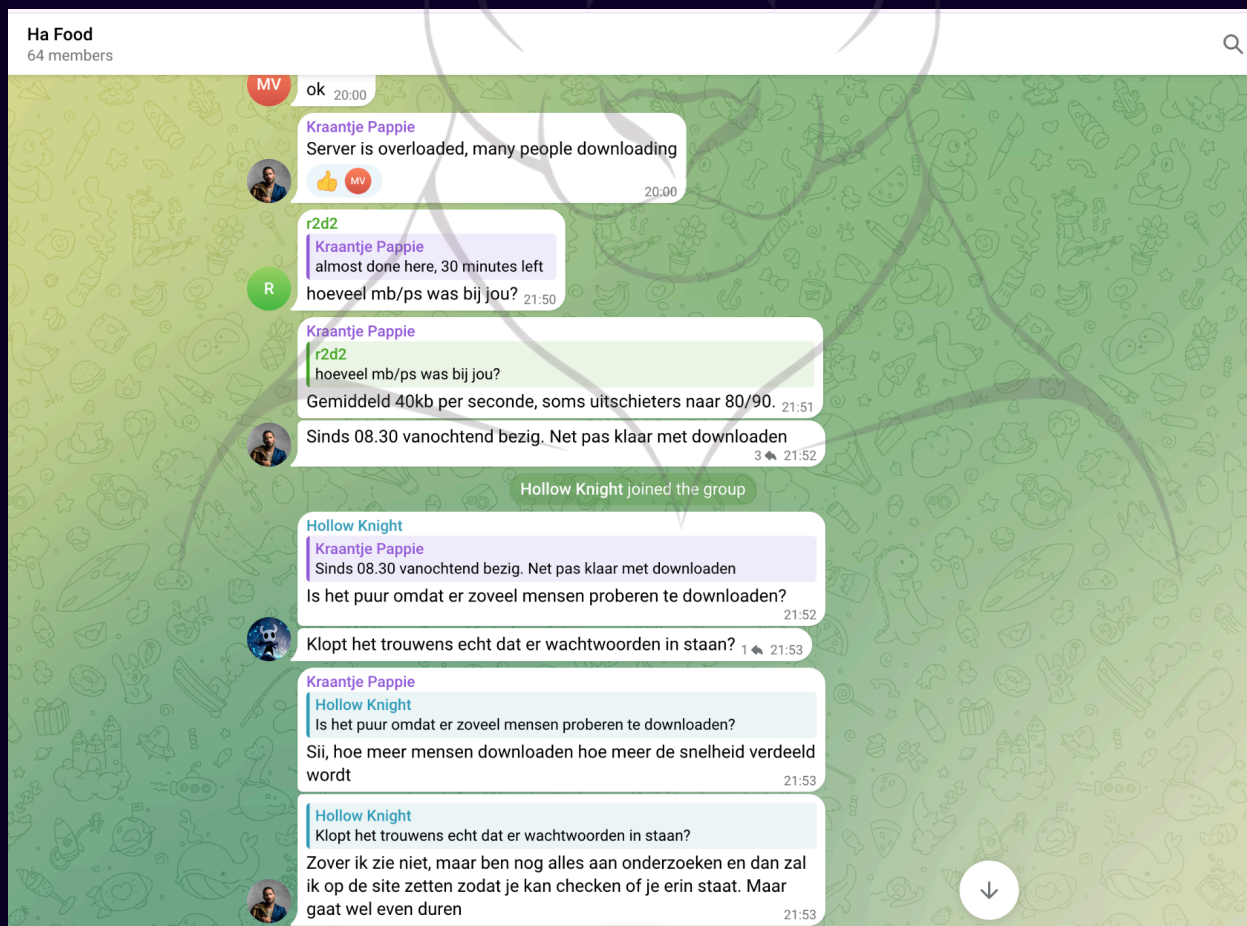
[Figure 9: Telegram Ha Food group — Odido leak links shared, server overload discussed, data completeness verified]



[Figure 10: Telegram Ha Food group — Split archive files (odido_1m/2m/3m_shinyhunters.txt.7z) distributed]



[Figure 11: Telegram Ha Food group — "Server is overloaded, many people downloading" — data quality verification in progress]





Secondary Impact Assessment

Data redistribution via Telegram multiplies victim impact: each affected individual faces risks from multiple downstream actors (identity theft, fraud, targeted phishing) beyond the original ShinyHunters extortion. Dutch nationals from the Odido breach face years of exposure risk from their IBAN, BSN, passport numbers, and plaintext passwords being freely circulated.

ShinyHunters Alliance Telegram Channels

Channel	Purpose	Launch
Scattered LAPSUS\$ Hunters	Primary alliance coordination between ShinyHunters, LAPSUS\$, Scattered Spider	Aug 8, 2025
Sim Land (SL)	ShinyCorp admin channel; insider recruitment; SIM swapping coordination	Ongoing
BreachStars	Underground data trading platform; data sale listings	Ongoing

Indicators of Compromise (IOCs)

Network & IP Indicators — HIGH CONFIDENCE

Type	Indicator	Confidence
IPv4	191.96.207.179	HIGH
IPv4	196.251.83.162	HIGH
IPv4	163.5.210.210	HIGH
IPv4	94.156.167.237	HIGH
IPv4	23.94.126.63	HIGH
IPv4	198.244.224.200	HIGH
IPv4	163.5.169.142	HIGH
Domain	bless-invite.com	HIGH
Domain	get-carrot-zoom.com	HIGH
Domain	modernatx-zoom.com	HIGH
Domain	recurly-zoom.com	HIGH
Domain	admiring-shockley.196-251-83-162.plesk.page	HIGH

Evilginx AiTM Phishing Domains — HIGH CONFIDENCE

Domain	Target
okta-louisvuitton.com	Luxury retail Okta impersonation • LVMH Korea breach Jul 2025
corporate-okta.com	Enterprise Okta impersonation
sharepoint-comcast.com	Microsoft SSO impersonation
workday-nike.com	Workday HR SSO impersonation
newscorp-okta.com	Media/telecom sector targeting
sts-vodafone.com	Telecom sector • US payment processing Q3 2025
signin-okta.com	Generic Okta impersonation
morningstar-okta.com	Financial services targeting
bmcorpuser.internal-okta.com	High-fidelity IOC • internal-okta subdomain pattern

File Hashes — Okta Phishing Kit (SHA-256)

Confidence	SHA-256
HIGH	0383c0d109b7cfdef058b0197125c85d276510724be33a746056f9a7c181d761
HIGH	e5c5617c8676e9a5cf6108d344fe7fcb6590671efd6baccb02b9313da0f0d289
HIGH	36de93aaf26727f6dd55ff2100b08dfb52abccfb57a7bf4d07a7fb703a86623d
MEDIUM	6aa51de51a6b352fd073b5b9080011d358d42fa190a8a9ee216e3ef6e657b801
MEDIUM	4e20f2c4c90e3654a8c43fb10003978d61d2b48426414dede3b1bd5a2c891b54

Cryptocurrency & Contact Identifiers

Type	Identifier	Confidence
BTC Address	bc1q5530apqz86eywm2f84mpcyuux3dv9mmztsdxt2	HIGH
XMR Address	87cEqA6PunENHwe5h8XtRifWuDhNQXKwzGNSbwKmrDEehY4wjRjWvZmSgE8LHTe6e5Pmnuyyiu5AWbGCC9gHUzUj5KHnSH9	HIGH
qTox ID	BD1B683FD3E6CB094341317A4C09923B7AE3E7903A6CDB90E5631EC7DC1452636FF35D9F5AF2	HIGH

Dark Web DLS Onion Addresses

Address
toolatedhs5dtr2pv6h5kdraneak5gs3sxrecqhufc5e45edior7mqd[.]onion
shinypogk4jjniry5qi7247tnop6mxdrdte2k6pdu5cyo43vdzmrwid[.]onion

Behavioral Indicators

Indicator Type	Description
Salesforce User Agent	Presence of 'RapeForce' substring in Salesforce API access logs • HIGH severity active exploitation IOC
Apache Server Header	Apache/2.4.58 (Win64) OpenSSL/3.1.3 across all phishing infrastructure • centralized management fingerprint
Salesforce Log Pattern	Bulk unauthenticated GraphQL queries to /s/sfsites/aura endpoint; high volume record retrieval from guest user profiles
OAuth Token Pattern	New Connected App tokens created via /setup/connect flow during or after unsolicited IT support calls

References & Intelligence Sources

This report is classified TLP:WHITE and may be freely shared for defensive purposes. All IOCs and attribution assessments have been cross-referenced across minimum two independent sources.

Primary Sources — March 2026

- [1] BleepingComputer (L. Abrams, Mar 2026) • ShinyHunters claims ongoing Salesforce Aura data theft attacks
<https://www.bleepingcomputer.com/news/security/shinyhunters-claims-ongoing-salesforce-aura-data-theft-attacks/>
- [2] Google Cloud / Mandiant (Mar 2026) • Expansion of ShinyHunters: SaaS Data Theft & AuralInspector Misuse (UNC6040 Profile)
<https://cloud.google.com/blog/topics/threat-intelligence/expansion-shinyhunters-saas-data-theft>
- [3] EclecticIQ (Sep 2025) • ShinyHunters Calling: Financially Motivated Data Extortion Group Targeting Enterprise Cloud Applications
<https://blog.eclecticiq.com/shinyhunters-calling-financially-motivated-data-extortion-group-targeting-enterprise-cloud-applications>
- [4] Varonis (Sep 2025) • What Salesforce Organizations Need to Know About ShinyHunters and Vishing (UNC6040)
<https://www.varonis.com/blog/salesforce-vishing-threat-unc604>
- [5] Wikipedia • ShinyHunters Group Profile & Major Breach Timeline (Snowflake/Salesforce)
<https://en.wikipedia.org/wiki/ShinyHunters>
- [6] Vectra AI • Modern Attack Analysis: ShinyHunters Ransomware & Data Theft Threat Assessment
<https://www.vectra.ai/modern-attack/threat-actors/shinyhunters>
- [7] CISA (Cybersecurity & Infrastructure Security Agency) • Review of LAPSUS\$ and Related Threat Groups (UNC3944/UNC6040 Clusters)
<https://www.cisa.gov/resources-tools/reports/csrb-report-lapsus>
- [8] Mandiant / MITRE Mapping • Threat Actor Profile: UNC6040 (The ShinyHunters Cluster) TTPs
<https://www.mandiant.com/resources/blog/unc6040-shinyhunters-saas-attacks>

© 2026 PROUDSEC Cyber Threat Intelligence. TLP:WHITE • Freely shareable for defensive purposes. Version 2.0 • March 10, 2026. Prepared by: Emircan ALTUNTAŞ, PROUDSEC Threat Intelligence Analyst.